

Top 5 Defects

& Release Recommendation

Defect 1

Unauthorized Fund Transfer From Another User's Account via API

Severity	High
Priority	High

Description

A security issue was found in the Transfer Funds API. After logging in using Account (X) credentials, the user can successfully transfer money from another account (Y) without authorization or ownership verification.

The backend accepts the request and completes the transaction successfully, indicating that proper authorization validation is missing on the server side.

Preconditions

- User has valid login credentials for Account (X).
- Another account (Y) exists with an available balance.
- Transfer Funds API is available.
- User can send API requests using Postman.

Steps to Reproduce

1. Open Postman.
2. Log in using Account (X) credentials.
3. Retrieve the authentication token/session.
4. Send a Transfer Funds request.
5. Modify the source account parameter to Account (Y).
6. Enter the transfer amount.
7. Submit the request.
8. Verify the response and account balances.

Expected Result

- The backend should verify that the logged-in user has permission to transfer money from the selected source account.
- The request should be rejected if the source account does not belong to the logged-in user.
- API should return an authorization error.

Actual Result

- The transfer request is accepted successfully and the API returns 200 OK.
- Money is transferred successfully from Account (Y) to Account (X) without authorization validation.

Evidence

OverviewMahragaPOST https://parabank.parasoft.com/parabank/services_proxy/bank/transfer?fromAccountId=13677&toAccountId=13788&amount=30

SaveShare

POSThttps://parabank.parasoft.com/parabank/services_proxy/bank/transfer?fromAccountId=13677&toAccountId=13788&amount=30Send

ParamsAuthorizationHeaders (10)BodyScriptsSettingsCookies

noneform-datax-www-form-urlencodedrawbinaryGraphQL

Key	Value	Description	Bulk Edit
☒ username	emara		
☒ password	emara		
Key	Value	Description	

BodyCookies (1)Headers (9)Test Results200 OK · 240 ms · 333 BSave Response

PrettyRawPreviewVisualizeJSON

1 Successfully transferred \$30 from account #13677 to account #13788

PostbotCtrl Shift \

Find and replaceConsolePostbotRunnerStart ProxyCookiesVaultTrash

Defect 2

Unauthorized Access to Another User's Transaction Details via Transaction ID

Severity	High
Priority	High

Description

A security issue was found in the Find Transactions feature. A logged-in user can view another user's transaction details by entering a transaction ID that does not belong to them. The system does not validate transaction ownership before displaying the data.

Preconditions

- User has valid login credentials.
- User is logged into the system.
- Another user's transaction ID is available.
- Find Transactions feature is accessible.

Steps to Reproduce

1. Log in using User Account (X) credentials.
2. Navigate to the Find Transactions page.
3. Enter a transaction ID that belongs to another user (Y).
4. Click the search button.
5. Observe the displayed transaction details.

Expected Result

- The system should verify that the transaction ID belongs to the logged-in user's account.
- Transaction details of other users should not be accessible.
- The system should display an authorization error message (e.g., "Access Denied / Unauthorized Request").

Actual Result

- The system retrieves and displays the transaction details successfully.
- User (X) can view transaction information belonging to another user (Y).
- Sensitive financial data is exposed without authorization.

Evidence

The screenshot displays a web application interface for "Account Services". On the left, a sidebar lists various services like "Open New Account", "Accounts Overview", "Transfer Funds", "Bill Pay", "Find Transactions", "Update Contact Info", "Request Loan", and "Log Out". The main content area shows an "Accounts Overview" table with columns for Account, Balance*, and Available Amount. A transaction ID "16008" is highlighted in the Account column, with a red arrow pointing to it. Below the table, a note states: "*Balance includes deposits that may be subject to holds".

To the right of the web application, a network packet capture (Wireshark) is shown. It displays a list of captured packets, with the selected packet being a response from the server. The packet details pane shows the response body, which is a JSON object containing transaction details. A red arrow points to the "id" field in the JSON object, which has the value "21580". This indicates that the system returned transaction details for a different user's ID (21580) instead of the requested ID (16008).

Defect 3

Unauthorized Modification of Another User's Contact Information via API

Severity	High
Priority	High

Description

A security issue was found in the Contact Information feature. A logged-in user (X) can update the contact information of another user (Y) by sending an API request containing user (Y)'s details. The server accepts the request and returns 200 OK, and the changes are reflected in user (Y)'s profile without proper authorization validation.

Preconditions

- User (X) has valid login credentials.
- User (Y) exists in the system.
- Contact Information update API is available.
- User can send API requests using Postman.

Steps to Reproduce

1. Log in using User (X) credentials.
2. Retrieve the authentication token.
3. Open Postman.
4. Send an update contact information API request.
5. Modify the request data to include User (Y) information.
6. Submit the request.
7. Log in to User (Y)'s account and check the contact information.
8. Verify that the changes are reflected on the contact info page.

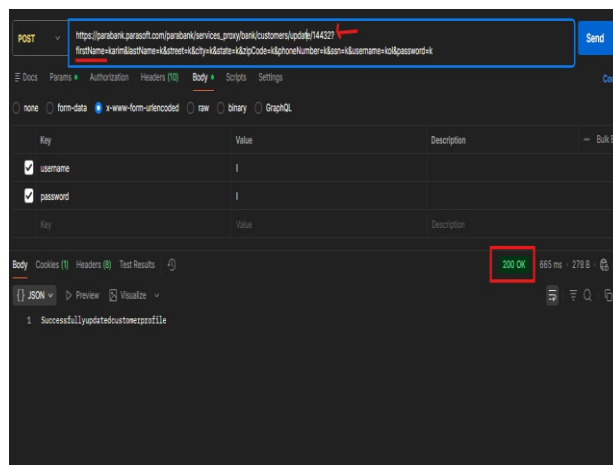
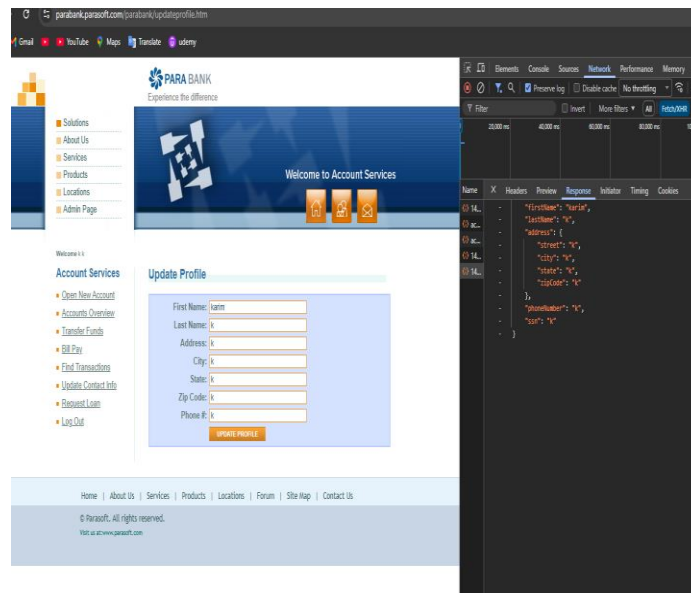
Expected Result

- The system should verify that the logged-in user has permission to update the provided account information.
- User (X) should not be able to modify User (Y)'s contact details.
- The API should return an authorization error.

Actual Result

- The API request is accepted successfully.
- Server returns 200 OK.
- User (Y)'s contact information is updated successfully without authorization validation.

Evidence



Defect 4

User Can Transfer Funds Exceeding Available Account Balance

Severity	High
Priority	High

Description

A business logic issue was found in the Transfer Funds feature. The system allows users to transfer an amount that exceeds the available balance in their savings account. The transaction completes successfully and the account balance becomes negative instead of being rejected due to insufficient funds.

Preconditions

- User has a valid account with an available balance.
- User is logged into the system.
- Transfer Funds feature is available.
- Account balance is less than the transfer amount.

Steps to Reproduce

1. Log in to the application.
2. Navigate to the Transfer Funds page.
3. Select the savings account.
4. Enter a transfer amount greater than the available account balance.
5. Submit the transfer request.
6. Check the transaction result and account balance.

Expected Result

- The system should validate the available balance before processing the transfer.
- The transfer request should be rejected if the amount exceeds the account balance.
- An error message should be displayed, such as "Insufficient funds."
- The account balance should remain unchanged.

Actual Result

- The transfer request is processed successfully.
- The system returns a successful response.
- The account balance becomes negative after the transfer.

Evidence



Welcome to Account Services





Accounts Overview

Account	Balance*	Available Amount
13677	\$165.50	\$165.50
14454	\$2326.00	\$2326.00
15342	\$1000.00	\$1000.00
16452	\$1000.00	\$1000.00
17673	-\$100.00	\$0.00
Total		\$4391.50

*Balance includes deposits that may be subject to holds

Name

X

Headers

Payload

Preview

Response

Initiator

Timing

Cookies

accounts

1 Successfully transferred \$200 from account #13673 to account #13677

transferFromAccount

accounts

Name	X	Headers	Preview	Response	Initiator	Timing
(X) accounts	-	-	-	"balance": 155.50	-	-
(X) transfer?fromAccou...	-	-	-	{	-	-
(X) accounts	-	-	-	"id": 14454,	-	-
	-	-	-	"customerId": 12545,	-	-
	-	-	-	"type": "LOAN",	-	-
	-	-	-	"balance": 2326.00	-	-
	-	-	-	},	-	-
	-	-	-	{	-	-
	-	-	-	"id": 15342,	-	-
	-	-	-	"customerId": 12545,	-	-
	-	-	-	"type": "LOAN",	-	-
	-	-	-	"balance": 1000.00	-	-
	-	-	-	},	-	-
	-	-	-	{	-	-
	-	-	-	"id": 16452,	-	-
	-	-	-	"customerId": 12545,	-	-
	-	-	-	"type": "LOAN",	-	-
	-	-	-	"balance": 1000.00	-	-
	-	-	-	},	-	-
	-	-	-	{	-	-
	-	-	-	"id": 17673,	-	-
	-	-	-	"customerId": 12545,	-	-
	-	-	-	"type": "SAVINGS",	-	-
	-	-	-	"balance": -100.00	-	-
	-	-	-	}	-	-
	-	-	-	}	-	-

Defect 5

Request Loan Approves a Loan When Available Funds Threshold Validation Is Not Applied Correctly

Severity	High
Priority	High

Description

When the Loan Processor setting is configured from the Admin page as Available Funds with a 20% threshold, the Request Loan feature should validate that the applicant's account balance meets the required threshold before approving the loan. However, the system approves the loan request even when the available account balance is below the required 20% threshold.

Preconditions

- Admin user has access to Loan Settings.
- Loan Processor is configured as Available Funds.
- Threshold is configured as 20%.
- User has an active account with a balance of \$199.
- User is able to access the Request Loan feature.

Steps to Reproduce

1. Navigate to the Admin page.
2. Set Loan Processor = Available Funds.
3. Set Threshold = 20%.
4. Save the configuration.
5. Navigate to Request Loan.
6. Enter Loan Amount: \$1000.
7. Enter Down Payment: \$0.
8. Select an account with balance: \$199.
9. Submit the loan request.

Expected Result

- The system should reject the loan request because the account balance does not meet the required threshold.
- Required funds = $20\% \times \$1000 = \200 .
- Available balance = \$199 (below required amount).

Actual Result

- The system approves the loan request even though the available account balance is below the configured 20% threshold.

Release Recommendation

Release Status: Blocked

Reason

The release must not proceed because blocker-level defects have been identified in critical banking functionalities. These issues affect core account operations and financial workflows, and may result in incorrect transactions, security risks, and data integrity problems.